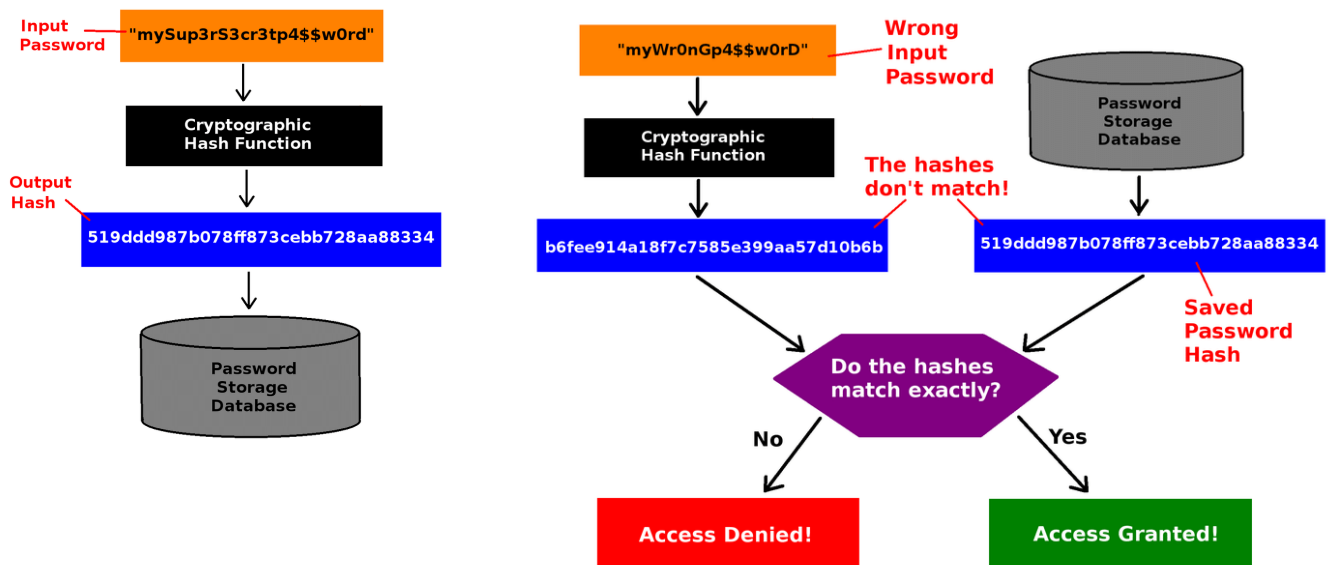


Anwendung: Passwörter als Hashwert speichern

Passwörter sollten aus Sicherheitsgründen niemals im Klartext gespeichert werden, sondern als Hash. Dies ist in der EU auch gesetzlich vorgeschrieben und Verstöße werden mit hohen Bußgeldern bestraft.

Prinzip

Die Berechnung des Passwortes zum Hash ist einfach – nicht jedoch andersherum. Werden die Passwort-Hashes gestohlen, so kann nicht auf die Passwörter geschlossen werden. Wird ein Passwort eingegeben, so werden nicht die Passwörter verglichen, sondern der berechnete Hash mit dem in der Datenbank gespeicherten Hash:



Angriffsmöglichkeiten bei gestohlenen Hashes

Brute-Force Angriff

Dieser Angriff testet die Hashes jeder möglichen Zeichenkette bis zu einer bestimmten Länge. Die Methode benötigt zwar die meiste Rechenzeit, mit genug Zeit aber, wird das Passwort gefunden. Das lässt sich verhindern, indem lange Passwörter genutzt werden, sodass sich der Aufwand nicht mehr lohnt.

Dictionary Angriff

Der Angriff findet mit einer Datenbank statt, in der Wörter, Phrasen und Zeichenketten gespeichert sind, die sich als Passwort eignen. Die Hashes werden dann mit denen der Passwörter verglichen. Gefüllt werden die Dateien mit Wörtern aus Texten und gestohlenen Passwörtern.



Rainbow-Table Angriff

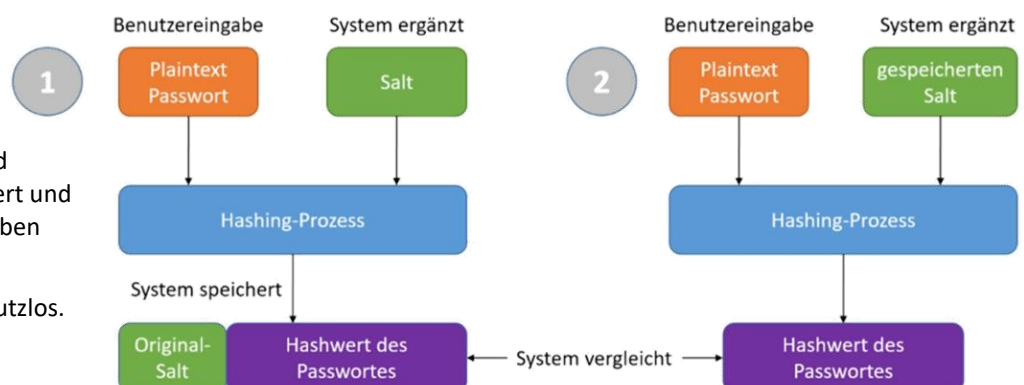
In Rainbow-Tables sind alle möglichen Passwörter bis zu einer bestimmten Länge und die dazu im Voraus berechneten Hashes abgelegt. Ein gestohlener Hashwert kann in der Rainbow Table nachgeschlagen werden. Bei einem Treffer ist auch automatisch das dazugehörige Klartext-Passwort bekannt.

Gegenmaßnahmen bei Rainbow-Table Angriffen

Passwort durch Salt ergänzen

Der Salt ist eine zufällige Zeichenkette, die an das Passwort angehängt wird, bevor der Hash erzeugt wird. Der Salt wird zusammen mit dem Hash gespeichert und für den Abgleich mit Benutzereingaben gespeichert.

Rainbow-Tables werden dadurch nutzlos.



Wahl eines sicheren und möglichst langen Passworts

- Es ist wichtig, dass Sie sich **das Passwort gut merken können**. Hierfür gibt es unterschiedliche Hilfsstrategien: Der eine merkt sich einen Satz und benutzt von jedem Wort nur den 1. Buchstaben (oder nur den zweiten oder letzten). Anschließend verwandelt man unter Umständen noch bestimmte Buchstaben in Zahlen oder Sonderzeichen. Die andere nutzt einen ganzen Satz als Passwort oder reiht unterschiedliche Wörter, verbunden durch Sonderzeichen, aneinander. Eine weitere Möglichkeit besteht darin, zufällig 5-6 Worte aus dem Wörterbuch zu wählen und diese mit einem Leerzeichen zu trennen. Dies resultiert in einem leicht zu merkenden, leicht zu tippenden und für Angreifer schwer zu brechenden Passwort.
- Grundsätzlich gilt: **Je länger, desto besser**. Um vor Rainbow-Table Angriffen (mit Hashes ohne Salt) ausreichend sicher zu sein, sollte das Passwort **mindestens 12 Zeichen** lang sein (Stand 2020). Bei Verschlüsselungsverfahren für WLAN wie zum Beispiel WPA2 oder WPA3 sollte das Passwort **mindestens 20 Zeichen** lang sein.
- Für ein Passwort können in der Regel **alle verfügbaren Zeichen** genutzt werden, beispielsweise **Groß- und Kleinbuchstaben, Ziffern und Sonderzeichen (Leerzeichen, ?!%+...)**. Manche Anbieter von Onlinediensten machen technische Vorgaben für die verwendbaren bzw. zu verwendenden Zeichen. Wenn Ihr System Umlaute zulässt, bedenken Sie bei Reisen ins Ausland, dass auf landestypischen Tastaturen diese eventuell nicht eingegeben werden können.
- Nicht als Passwörter geeignet sind Namen von Familienmitgliedern, des Haustiers, des besten Freundes, des Lieblingsstars, Geburtsdaten und so weiter. Das vollständige Passwort sollte möglichst **nicht in Wörterbüchern** vorkommen. Es sollte zudem nicht aus gängigen Varianten und Wiederholungs- oder Tastaturmustern wie "asdfgh" oder "1234abcd" bestehen. Manche Anbieter gleichen Passwörter gegen eine sogenannte "black list" ab, in der genau solche nicht geeigneten Passwörter hinterlegt sind. Möchte man sie nutzen, erhält man einen Hinweis, dass das Passwort in dieser Form nicht zugelassen wird bzw. nicht sicher ist.
- Einfache Ziffern am Ende des Passwortes anzuhängen oder eines der üblichen Sonderzeichen \$! ? # am Anfang oder Ende eines ansonsten simplen Passwortes zu ergänzen, ist nicht empfehlenswert.
- Nutzen Sie einen **Passwortmanager**, um Ihre unterschiedlichen Passwörter gut verwalten zu können. – und ihr starkes Passwort, um diesen abzusichern. So müssen Sie sich nur ein gutes Passwort merken und können trotzdem **überall sehr starke und unterschiedliche Passwörter** verwenden.

Zwei-Faktor-Authentisierung für höhere Sicherheit

Mittlerweile bieten viele Online-Dienstleister Verfahren an, mit denen die Nutzer sich zusätzlich zur Passworteingabe identifizieren können, wenn sie sich in ein Konto einloggen. Diese sogenannte Zwei-Faktor-Authentisierung gibt es in zahlreichen Varianten, die vom individuellen Code per SMS bis zu einem hardware-gestützten TAN-Generator reichen können. Dabei bieten vor allem hardware-gestützte Verfahren ein hohes Maß an Sicherheit und sollten wenn möglich ergänzend zu einem starken Passwort genutzt werden.